25-26 IY3660: Applications of Cryptography

Main content blocks

Skip Key information for IY3660

Key information for IY3660

Course staff:

- **Teaching: Dr. Elizabeth Quaglia**
  - **office: Bedford**
  - **office hours: Wednesdays 13:00 - 14:00 and by appointment**
  - **email: Elizabeth.Quaglia@rhul.ac.uk**
- **Teaching Assistants / Tutors: Benjamin Benčina and Simon Pohmann**

Lecture times:

- **Wednesday, 10:00 to 12:00 Bourne Annexe 290**
- **Thursday, 11:00 to 12:00 Bedford 0-04-06**

Week 1 is Welcome week.

We will hold six lab sessions in the Thursday 11:00 to 12:00 slot.

- **Lab dates: 16 Oct, 23 Oct, 30 Oct, 13 Nov, 20 Nov and 11 Dec 2025**

Important Information for Students Retaking This Module

If you are repeating this module, please attempt all Coursework (CW) assessments posted during term time. However, if you are resitting the module and are supposed to attempt CW assessments again, then please do not attempt in-term CW. There will be a dedicated CW resit in the April/May 2026 assessment period.

Skip Learning outcomes

Learning outcomes

By the end of this module students should be able to:

- **explain what cryptography can be used for**
- **describe several cryptographic mechanisms for providing each of the core security services**
- **appreciate the differences between various types of cryptographic mechanisms and in which situations they are most usefully employed**
- **identify the issues that need to be addressed when assessing what types of cryptographic mechanism are necessary to "*secure*" an application**

- **identify the limitations of cryptography and how to support it within a full security architecture**

Skip Essential reading material

Essential reading material

The two books below are in the course's official reading list, and should be used on a regular basis to reinforce what you will learn in class:

- **Everyday Cryptography (2nd edition), by Keith Martin.**
  Oxford University Press 2017, ISBN: 0198788010
  Provide a broad coverage of cryptography, following a mostly non-mathematical approach
- **Serious Cryptography, by Jean Philippe Aumasson**
  No Starch Press, 2017, ISBN 978-1593278267
  A "practical guide" to modern cryptography

Topic outline

- Collapse all

Further reading material:

Here are two further resources (available online) that you can use to support your learning.

  - Applied Cryptography Knowledge Area – Version 1.0.0**, Kenneth G. Paterson**
    Part of CyBOK (Cyber Security Body Of Knowledge) project**, this KA document "provides a broad introduction to the field of cryptography, focusing on applied aspects of the subject". It features essentially the same structure as our course. A highly recommended reading!**
  - A Graduate Course in Applied Cryptography**, Dan Boneh and Victor Shoup**
    Still unfinished, but provides a *comprehensive* and *in-depth* coverage of applied cryptography (it goes deeper and beyond what we cover in the course, but it is an *excellent* resource to support your learning and for students who wish to learn more about applied cryptography)

Announcements will be posted in the forum:

  -

Announcements forum

- **Summative Assessment**

The Summative Assessment is due on Thursday 4th December at 2pm.

  -

IY3660 CW 2526 File

IY3660 Summative AssessementTurnitin Assignment

Summative Assessment with ExtensionTurnitin Assignment

- **Week 1: Welcome week**

Welcome to the IY3660 module!

My name is Dr Elizabeth Quaglia, and I am the module leader. I am a Reader in the Information Security Group, and my main area of research is cryptography.

While you are enjoying welcome week, take some time to post a brief message in the "Introductions forum" to introduce yourself. If you are viewing this text from the main IY3660 page, then clicking on "Week 1: Welcome week" will take you to the page on which the forum can be found.

Let us know what brought you to this module, what your interests and background in cryptography (if any) are, and what you expect from the module.

I look forward to meeting all of you next week!

IY3660 Introductions forum

- **Week 2: Intro and Historical Ciphers**

We begin by giving general information about the course. We will also set the scene for our teaching, and learning, of cryptography and introduce some classic ciphers. We then move on to introduce stream ciphers.

Note that the recordings of each sessions can be found in the RePlay section in the right-hand column.

Week2-Lecture File

Week 2 Quiz - Answers on last page File

-

Funwithciphers File

-

Funwithciphers withsolutions File

- **Further reading & research**

Do some research on the Kasiski method, which is the classic method for recovering the length of the key(word) in the Vigènere cipher. Of course, if you believe the keyword is not too long, you could always repeatedly guess a length, and run the attack, until you recover the message... what do you think is a better approach?

Below:

- **A 1994 CRYPTOLOGIA article by Boris Hagelin & David Kahn about the (classic) cipher machines invented by Boris Hagelin, widely used in WWII. Hagelin then went to found CRYPTO AG in Switzerland, which until very recently supplied cryptographic machines to governments and businesses.**
- **Link to the eSTREAM project, a project to promote the design of efficient and compact stream ciphers**
- **2015 essay by Phil Rogaway on the "Moral Character of Cryptographic Work"**

-

Story of the Hagelin Cryptos File

-

eSTREAM: the ECRYPT Stream Cipher ProjectURL

-

Rogaway - The Moral Character of Cryptographic WorkURL

- **Week 3: OTP, Stream Ciphers and Block Ciphers**

We discuss the one-time pad, stream ciphers and block ciphers this week. We will define block ciphers as a cryptographic primitive, discuss their security, and go through the most popular constructions, e.g., the AES block cipher.

-

Week3-OTPStreamCiphers File

-

Week3-BlockciphersDesign File

-

Week 3 Quiz File

-

Week3-Workshop File

-

Week 3 Quiz with Answers File

-

Week3-WorkshopwithAnswers File

- **Further Reading & Research**

  -

Making of Rijndael, by Joan DaemenURL

This presentation, given at the AES Day event in 2012, takes you through the design of AES, starting from Joan's research during his PhD studies to the proposal of Rijndael (with a few events in between). It may be a bit too technical in parts, but interesting to see what is behind the design of AES.

  -

An AES Retrospective, by Miles Smid (NIST)URL

Another talk from the same event, with an overview of the AES competition and standardisation process.

  -

Understanding cache attacks (against AES)URL

The AES is a very secure block cipher, but it is susceptible to side-channel attacks when implemented in software using look-up tables. Other works include Cache-timing attacks on AES, by D. Bernstein, and Efficient Cache Attacks on AES, and Countermeasures, by Tromer, Osvik and Shamir.

  -

Lightweight block cipher zoo (by Uni Lux)URL

It gives a short intro to the topic, a table with several ciphers (with parameters, security, etc), followed by details of those ciphers.

▪

NIST lightweight cryptography project and competitionURL

You may also want to have a look at NIST's 2017 Report on Lightweight Cryptography to learn more lightweight cryptography.

▪

COPACOBANA: A Codebreaker for DES and other CiphersURL

The *Cost-Optimized Parallel Code Breaker (COPACOBANA)* machine, is a high-performance low-cost cluster consisting of 120 field-programmable gate arrays (FPGAs), developed by the team at Ruhr University Bochum. It is optimised for code breaking tasks; see for example "How to Break DES for Euros 8,980".

- Week 4: Block Cipher Modes of Operation and Security Models

A n-bit block cipher can only encrypt messages of *exactly* n bits. If we want to encrypt a message of arbitrary length, we need a *mode of operation*. This week, we introduce the main block cipher modes of operation (ECB, CBC, CTR, CFB, OFB), and discuss their features and security.

We also introduce security models in modern cryptography.

○

Week4-Lecture File

○

Week4-Securitymodels File

○ Further Reading & Research

▪

Zerologon – hacking Windows servers with a bunch of zerosURL

A blog entry from Sep 2020, by Sophos, with a very didactic explanation of bug in Windows's Zerologon service (discovered and first introduced by researchers from Secura here). It discusses how Zerologon authentication works, modes of operation, and how one may exploit the flawed implementation of AES in CFB mode to defeat it. As they write early on, the story demonstrates two very important lessons: cryptography is hard to get right; and cryptographic blunders can take years to spot.

- Move Fast and Roll Your Own Crypto -- A Quick Look at the Confidentiality of Zoom MeetingsURL

  This report, by Citizen Lab researchers, examines the encryption mechanisms that protected meetings in the popular Zoom teleconference app. They find that Zoom had "rolled their own" encryption scheme, which had significant weaknesses. They also identified potential areas of concern in Zoom's infrastructure, including observing the transmission of meeting encryption keys through China (see also this blog entry).

  (update: later Zoom improved its cryptography, see for example this post)

- How the BEAST Attack WorksURL

  Blog entry describing the BEAST attack against SSL/TLS. The attack is a practical example on how to attack an implementation of CBC mode with predictable (or known) IVs.

- Security Flaws Induced by CBC Padding Applications to SSL, IPSEC, WTLS... (by Vaudenay, Eurocrypt 2002) File

  Research paper from 2020 by Serge Vaudenay, in which padding oracle attacks were first introduced. The attack was shortly after improved to apply against SSL/TLS (several further improvements have since appeared).

- Cryptography in Theory and Practice: The Case of Encryption in IPsec (by Paterson and Yau, Eurocrypt 2006) File

  A research paper from 2006 by Paterson and Yau, describing attacks on the Linux kernel implementation of IPsec encryption-only ESP in tunnel mode, which exploits bit flipping in CBC mode, due to the lack of integrity protection for the IV. In some cases, the attacks are both realistic and efficient, and recover the complete contents of IPsec-protected datagrams.

- the cryptopals crypto challengesURL

  For students who want to get their teeth into some coding, you may want to try the Matasano crypto challenges. By the end of this week, you should have enough knowledge to attempt challenges 1-27.

▪

Sweet32 attackURL

Attack exploiting the use of block ciphers with small block size (eg 64-bit block DES) when used by TLS (and other protocols).

- **Lab 1**

Lab 1 will be held on 16th October.

Below you will find the lab sheet that we will work through, as well as:

  - **A sheet giving information on installing Sage, which we will use in the labs**
  - **A sheet giving information on converting Java to Sage, in case you are more familiar with Java than Python or Sage.**

A solution sheet will be uploaded after the lab session.

  - Lab 1 Worksheet File
  - Java to Python conversion sheet File
  - Sage installation instructions File
  - Lab 1 Solutions File

- **Week 5: Hash functions**

Cryptographic hash functions are known as the *Swiss Army knife* of modern cryptography. They are *easy-to-compute* functions that take inputs of arbitrary length and produce outputs of fixed length (a *digital fingerprinting* of the input data). This week we will introduce hash functions, discuss their security properties, and go through the main constructions.

  - Week5-Lecture File

Week 4 Quiz File

- Further Reading & Research

  - Hash function design and cryptanalysis: basic topics (by Bart Preneel)URL

    Slides for a talk on hash functions by Bart Preneel (KU Leuven). Covers what we discussed in class, and more.

  - Building Hash Functions from Block Ciphers (by Timo Bartkewitz) File

    An article discussing the methods for constructing a hash function from a compression function that is built from a block cipher.

  - SHA-3 ZooURL

    Page with cryptographic hash functions submitted to the SHA-3 competition (note: as one would expect, it looks like the page is no longer maintained; however it still useful).

  - The sponge constructionURL

    Explanation by the Keccak team. Also in simpler terms in the wikipedia page.

  - Hash length-extension attacksURL

    A blog post discussing how one may explore the Merkle-Damgard construction for hash function (used in, eg MD5, SHA-1 and SHA-2 hash functions) to mount a *length-extension attack*. In this attack, given the hash of an *unknown* message M, you are able to obtain the hash of a message P which has M as prefix. The post explains how this property was used in a real-world attack.

  - Analyzing the MD5 collision in Flame (by Alex Sotirov)URL

    Slides explaining how MD5 collisions were explored to build the Flame malware. See also here.

  - SHA-1 is a Shambles!URL

Page explaining the most recent attack against SHA-1 (Jan 2020). It reports the computation of chosen-prefix collisions for SHA-1 (with practical complexity), and how to use them to compromise PGP/GnuPG Web of Trust application. Main take: SHA-1 should no longer be used (where collision-resistance is a security requirement, eg digital certificates)

- **Hash functions, random oracles and indifferentiabilityURL**

Blog entry (by Matthew Green) discussing the notion of *indifferentiability* and random oracles.

- **Reversing CRC – Theory and Practice (by M. Stigge et al.) File**

CRCs (Cyclic Redundancy Checks) are non-cryptographic hash functions, used for providing (non-cryptographic) checksums, which would typically detect *accidental* change in data. This paper discusses how to manipulate CRCs, to construct matching functions.

- **Lab 2**

Lab 2 will be held on 23rd October.

Below you will find the lab sheet that we will work through.

A solution sheet will be uploaded after the lab session.

- **Lab 2 Worksheet File**
- **Lab 2 Target Server Script File**
- **Lab 2 attack skeleton File**
- **Lab 2 solution code File**

- **Week 6: Hash Function applications and MACs**

This week we will continue our study of hash functions and explore some of their applications.

We then introduce Message Authentication Codes (MACs). These are keyed (symmetric) primitives used to provide data integrity and data origin authentication. We define what MACs are, and discuss the security notion for MAC algorithms (*unforgeability under chosen message attacks -- UF-CMA*).

-

Week6-Lecture File

- **Further Reading & Research**

  -

Password Security: A Case History (Morris and Thompson, 1974) File

A classical paper, putting forward the design principles for protection of passwords using hash functions (or better one-way functions).

  -

An Assessment of the Oracle Password Hashing Algorithm (Wright and Cid, 2005) File

An article (which I co-authored) describing the inner workings and vulnerabilities in the Oracle password hashing algorithm (used in 2005, since then changed). It illustrates how things can go wrong.

  -

World's Biggest Data Breaches & HacksURL

Nice visualisation!

  -

Cracking Passwords With Time-memory Trade-offs (Gildas Avoine)URL

Presentation slides discussing advanced techniques for password recovery.

- The ‘Cracken’: The Evolution of Password CrackingURL

A two-part (short) article discussing IBM’s password cracking tool, Cracken. The second part is here.

- Anatomy of a hack: How crackers ransack passwords like “qeadzcwrsfxv1331”URL

ArsTechnica article (from 2013) describing a password cracking effort.

- The scrypt key derivation functionURL

Page with information about the scrypt hash function. See also the original paper introducing the concepts of memory-hard algorithms and sequential memory-hard functions, as a form of protecting against attacks using custom hardware. Another good discussion can be found in this page.

- Key Derivation FunctionsURL

Wikipedia page on Key Derivation Functions (KDF). HKDF is a KDF based on HMAC.

- Password Hashing Competition websiteURL

Competition to select hash function algorithms suitable for password hashing. Winner was Argon2, a memory-hard hash function.

- Proof-Of-WorkURL

wikipedia page explaining the principles of proof-of-work systems.

- Hashcash proof-of-workURL

A wiki page discussing the hashcash proof-of-work scheme used in bitcoin. See also here.

- Lab 3

Lab 3 will be held on 30 October.

Below you will find the lab sheet that we will work through.

A solution sheet will be uploaded after the lab session.

- Lab 3 exercise sheet File

- Lab 3 skeleton code File

- **Week 7: Authenticated Encryption**

This week we introduce the notion of Authenticated Encryption (AE) security. Symmetric Encryption schemes are AE secure if adversaries with access to an encryption oracle cannot learn anything about plaintexts given the ciphertext; moreover they cannot forge ciphertexts that are accepted as authentic. We introduce several constructions that are AE secure.

- Silent drawings File

- Week7-Lecture File

- **Further Reading & Research**

  - CBC-MAC pageURL

Wiki page about CBC-MAC. It discusses the construction, the main attacks, and how to make it secure. Some however remain unconvinced: see the blog entry "*Why I hate CBC-MAC*" by Matthew Green.

  - HMAC - The Keyed-Hash Message Authentication CodeURL

Wiki page for the HMAC, a hash-based message authentication algorithm. HMAC is also specified as a NIST standard (FIPS 198-1).

- Notes on Information-Theoretic Message Authentication Codes File

This is a short document discussing *Information-Theoretic Message Authentication Codes*. A scheme offers information theoretic security if it offers security against adversaries with unbounded resources (e.g. the one-time-pad for encryption, against ciphertext-only adversaries). This is in contrast to *computationally* security, where adversaries are restricted to "reasonable" resources. The documents contains a brief overview of the main concepts, constructions and their security guarantees, and a discussion of options for information-theoretic MAC algorithms. It is quite mathematical, but gives you more information about the security of polynomial-based MACs (of which Poly-1305 and GMAC (used in GCM) are popular examples).

- How (not) to use symmetric encryptionURL

A blog post by Matthew Green (from 2011), discussing "Symmetric Encryption". See also the follow up post "*Are AEAD modes more vulnerable to side-channel attacks?*", and "*How to choose an Authenticated Encryption mode*" (from 2012).

- GCM mode of operationURL

Wiki page for the Galois Counter Mode (GCM) mode of operation for block ciphers. GCM is a mode that provides confidentiality (via CTR mode of encryption) and authenticity (via its GHASH function). AES-GCM (ie AES in the GCM mode) is the most popular AEAD scheme. The mode is officially defined as a NIST standard SP800-38D.

- Why AES-GCM Sucks!URL

Not everyone is a fan of AES-GCM.

- It takes two to ChaCha (Poly)URL

A Cloudflare blog post discussing ChaCha-Poly1305 AEAD scheme. This is the page about the Poly1305 authenticator by its designer, D. Bernstein (the original paper).

- OCB: authenticated encryption mode of operation for block ciphers.URL

OCB is a block cipher-based mode of operation that simultaneously provides both privacy and authenticity. OCB is very efficient, and achieves authenticated encryption in almost the same amount of time as the fastest conventional mode, CTR mode, achieves privacy

alone! The latest version of OCB (OCB3) was selected as one of the ciphers in the CAESAR competition portfolio. You can also read about OCB in its wiki page.

▪

CAESAR competition pageURL

Webpage for the CAESAR (Competition for Authenticated Encryption: Security, Applicability, and Robustness) competition. You can find information about all submissions and the six ciphers in the final portfolio here.

- Guest Lecture: Quantum Cryptography

On the afternoon session of Wednesday 6th November, Simon will give a guest lecture on the topic of Quantum Cryptography.

○

Lecture Slides File

- Week 8: Public Key Encryption

This week we start with our study of public-key cryptography. We introduce the notion of *Public-Key Encryption* (PKE), and define the security goal we will aim for (IND-CCA). We then briefly introduce a few basic concepts in number theory, which are the main tools for the study of public-key encryption algorithms. Some of the maths behind PKC is also the focus of this week's lab. We then cover the RSA public-key algorithm.

○

Week8-Lecture File

○

Week 7 Quiz File

○

Week 7 Quiz with answers File

○ Further Reading & Research

▪

Notes on Modular ArithmeticURL

Some brief notes on modular arithmetic. It also discusses Euclid's algorithm and computing inverses modulo a number.

▪

Generation of primesURL

Wiki page with an overview of the main methods for generating prime numbers.

▪

GCHQ pioneers on birth of public key crypto (ZDNet article)URL

The RSA algorithm was publicly introduced in 1977 by Rivest, Shamir and Adleman. However, several years later it was disclosed that GCHQ researchers had come up with an equivalent scheme a few years earlier -- see this NYT article and the wiki page about Clifford Cocks.

▪

Cryptanalysis of RSA: A Survey File

This is an accessible survey written by Carlos Cid (a previous module leader of IY3660) in 2003 about the cryptanalysis of the RSA cryptosystem. A more technical survey was written a few years earlier by D. Boneh.

▪

RSA Factoring ChallengeURL

Wiki page discussing the RSA Factoring Challenge, established in the early 1990s to encourage research into computational number theory and the practical difficulty of factoring large integers.

▪

keylength.com: cryptographic key length recommendationURL

Webpage with links/tables for the different methods for deriving key length from aimed bit-level of security.

▪

Mining Your Ps and Qs: Detection of Widespread Weak Keys in Network Devices (by Heninger et. al.)URL

Very interesting paper (from 2012) which found that a large number of RSA moduli in public-facing servers shared a prime. This is mostly due to malfunctioning random number generators, most likely due to insufficient entropy during key generation (e.g. when routers a factory-set and generate primes early in the set up process).

- **Lab 4**

Lab 4 will be held on 13 November.

Below you will find the lab sheet that we will work through.

A solution sheet will be uploaded after the lab session.

- **Lab 4 Exercise Sheet File**
- **Lab 4 Beginning Questions Errata File**

- **Week 9: Discrete Log-based Cryptography**

This week we introduce cryptographic schemes based on the *discrete logarithm problem (DLP)*. We define the discrete log setting for integers modulo a prime. Then we discuss the Diffie-Hellman key establishment protocol, the ElGamal public-key encryption, and the Diffie-Hellman Integrated Encryption Scheme. We will also introduce the Elliptic Curve setting.

- **Week9-Lecture File**
- **Further Reading & Research**
  - **Notes on Discrete LogarithmsURL**

More notes on basic number theory for cryptography. The link takes you to page on modular exponentiation and discrete log, but see also the discussion about generators and cyclic groups.

  - **Discrete Log Problem and AlgorithmsURL**

Wiki page with information about discrete logarithms, and algorithms for solving DL. For the mathematically inclined, who want to learn *much more* about DL and algorithms, I

strongly recommend chapters (available online) from S. Galbraith's book: "13-Basic Discrete Logarithm Algorithms", "Factoring and Discrete Logarithms using Pseudorandom Walks" and "Factoring and Discrete Logarithms in Subexponential Time".

- A (Relatively Easy To Understand) Primer on Elliptic Curve CryptographyURL

A Cloudflare blog entry with an ECC primer. See also the wikipedia page.

- Elliptic Curve Cryptography in PracticeURL

Article by Bos et al. with a review of elliptic curve cryptography (ECC), as it is used in practice (in 2013). The paper shows a few examples of mistakes and vulnerabilities that arise in implementations of ECC.

- Not Playing Randomly: The Sony PS3 and Bitcoin Crypto HacksURL

Medium post discussing attacks against Snoy PS3 and bitcoin implementations of ECDSA. The attacks exploit the fact the implementations did not use random values as required.

- SafeCurves: choosing safe curves for elliptic-curve cryptographyURL

- New Directions in Cryptography (by W. Diffie and M. Hellman)URL

The original Diffie & Hellman paper, from 1976, with the foundational ideas for public-key cryptography. Highly recommended reading.

- The Diffie-Hellman Problem and Cryptographic ApplicationsURL

Another chapter of Steven Galbraith's book, discussing the DH key establishment protocol and the ElGamal public-key encryption scheme. You can also have a look at the wikipedia page for some more facts about the protocol (and an interesting illustration of the protocol using different colour *paint*).

- Go Public and Symmetric Key? The Best of Both Worlds: ECIESURL

A brief Medium article by Bill Buchanan about *Elliptic Curve Integrated Encryption Scheme* (ECIES), a CCA-secure hybrid encryption scheme based on the Diffie-Hellman key exchange scheme.

- **Lab 5**

Lab 5 will be held on 20 November.

Below you will find the lab sheet that we will work through.

A solution sheet will be uploaded after the lab session.

- **Lab 5 sheet File**
- **iy3660_lab_05_rsa.py File**
- **iy3660_lab_05_rsa_attack.py File**
- **iy3660_lab_05_rsa_attack_auxiliary.py File**

- **Week 10: Digital Signatures**

This week we will conclude our journey in public-key cryptography by studying digital signatures.

- **Week10-Lecture File**
- **Further Reading & Research**
  - **Blind signaturesURL**

Wiki page discussing *blind signatures*. This is a form of signature scheme in which the message to be signed is first *blinded* before signing. They are mainly used in privacy-preserving protocols. Note also that blinding may give rise to attacks, e.g. RSA blinding signing attacks.

EUF-CMA and SUF-CMAURL

An entry in Matthew Green's blog discussing the (E)UF-CMA and SUF-CMA security notions for signature schemes.

How does ECDSA work in BitcoinURL

Medium entry discussing how ECDSA signatures work and used in bitcoin (see also links).

- Week 11

This week we will discuss key management.

In the workshop session there will be an opportunity for Q&A and revision.

Week11-Lecture File

- Week 12: TLS

This week we bring all of what we have studied together and discuss the TLS protocol. TLS is perhaps the most popular cryptographic protocol, and it is used to secure traffic in the Internet between browsers and web servers.

Week12-Lecture File

- Further Reading & Research

The Illustrated TLS ConnectionURL

Great webpage, showing in detail and explaining every byte exchanged during a TLS 1.2 Handshake, as a client connects to a TLS server, negotiates a TLS session, sends "ping", receives "pong", and then terminates the session. You can also try and compare with the TLS 1.3 version.

A Detailed Look at RFC 8446 (a.k.a. TLS 1.3)URL

An excellent blog entry by Nick Sullivan (from CloudFlare), discussing the TLS protocol and the main features in the new version TLS 1.3.

-

Perfect Forward Secrecy - An IntroductionURL

Blog entry discussing forward secrecy property of key agreement protocols.

-

The DROWN attackURL

A 2016 attack exploiting features of the TLS handshake (for configurations still supporting SSL v2).

-

The ROBOT (Return Of Bleichenbacher's Oracle Threat) attackURL

This is an attack from 2018, a "*return of a 19-year-old vulnerability that allows performing RSA decryption and signing operations with the private key of a TLS server*". It is a new take on Bleichenbacher's original million-message attack against implementations supporting PKCS #1 v1.5 padding (when using RSA for encryption of the pre-master secret in the handshake)

-

The FREAK attackURL

A attack from 2015, exploiting support of "export-grade" cryptography in some SSL/TLS configurations.

-

What is TLS? (by Cloudflare)URL

A Cloudflare article covering the basics of the TLS (Transport Layer Security) protocol.

-

The Heartbleed vulnerabilityURL

A software vulnerability in the OpenSSL library found in 2014. It is a bug is in the OpenSSL's implementation of the TLS/DTLS heartbeat extension (RFC6520). When it is exploited it leads to the leak of memory contents from the server to the client and from the client to the server.

-

OpenSSLURL

Wikipedia page about OpenSSL, a "robust, commercial-grade, and full-featured toolkit for the Transport Layer Security (TLS) and Secure Sockets Layer (SSL) protocols" (also a general-purpose cryptography library).

-

SSL Server Test (by Qualys)URL

Free online service which performs a deep analysis of the configuration of any SSL/TLS web server on the public Internet. Have a try!

- **Lab 6**

Lab 6 will be held on 11 December.

-

Lab 6 sheet File

-

Lab 6 code skeleton File